Auftragsverarbeitungsvertrag (AVV) / Data Processing Agreement (DPA)

Scandora — Managed AI, Cloud-Verlaufssynchronisation, serverseitiger DATEV-Export, GoBD-Aufzeichnungen & geräteübergreifendes Importregister · Art. 28 DSGVO / GDPR

Fassung / Version: 2026-10-17 (Rev. 11)

Entwurf — externe anwaltliche Prüfung ausstehend. / Draft — external counsel review pending.

Dieser AVV ist ein interner Entwurf, intern gegen die tatsächlichen Datenflüsse von Scandora geprüft. Er wurde noch nicht von externen Rechtsanwälten geprüft und kann sich ändern, bevor er zum Abschluss einer verbindlichen Vereinbarung verwendet wird. / This DPA is an internal draft, reviewed in-house against Scandora's actual data flows. It has not yet been reviewed by external legal counsel and may change before it is used to conclude a binding agreement.

Vertragsparteien / Contracting Parties

Verantwortlicher (Auftraggeber) / Controller (Customer)

Firma / Company: _____

Anschrift / Address: _____

Vertreten durch / Represented by: _____

E-Mail / Email: _____

Auftragsverarbeiter / Processor

Farhad Sanaei seresht (Einzelunternehmen, Geschäftsbezeichnung „Scandora“)

Burgunderweg 19G, 22453 Hamburg, Deutschland

E-Mail: privacy@scandora.eu

Deutsche Fassung (maßgeblich)

Auftragsverarbeitungsvertrag (AVV) gemäß Art. 28 DSGVO

Dieser Vertrag konkretisiert die datenschutzrechtlichen Pflichten der Parteien für die Verarbeitung personenbezogener Daten, die Scandora als Auftragsverarbeiter im Auftrag des Verantwortlichen durchführt. Er gilt ergänzend zu den Nutzungsbedingungen und der Datenschutzerklärung von Scandora.

Hinweis: Die Kontodaten des Verantwortlichen (E-Mail-Adresse, Name, Abonnement- und Abrechnungsdatensatz) sowie die E-Mail-Korrespondenz mit Scandora liegen außerhalb dieses AVV; insoweit ist Scandora Verantwortlicher aufgrund seines eigenen Vertrags mit dem Kunden. Der Verlaufseintrag unterfällt dagegen vollständig diesem Vertrag — der extrahierte Dokumenttext, das Vorschaubild und die Metadaten des Eintrags: Der Verantwortliche entscheidet, welche Dokumente gescannt und warum sie aufbewahrt werden; Scandora speichert den Eintrag daher als Auftragsverarbeiter und nutzt ihn für keine eigenen Zwecke. Abschnitt 8 der Datenschutzerklärung von Scandora führt Verlaufs-Metadaten unter der Verantwortlichenrolle von Scandora auf; das beschreibt die Nutzung ohne AVV, bei der die nutzende Person betroffene Person und nicht Verantwortlicher ist.

1. Gegenstand und Dauer

Gegenstand ist die Verarbeitung von Dokumentinhalten des Verantwortlichen auf fünf Wegen: (a) verwaltete KI (Managed AI) — für die Dokumentanalyse sowie für die Dokumentensuche und den Dokument-Chat fragt das Gerät, auf dem Scandora läuft, den KI-Modellanbieter direkt an, mit einer kurzlebigen Zugangsberechtigung (bis zu 30 Minuten), die der Server von Scandora ausstellt; die Suche und der Abruf für den Chat erfolgen auf dem Gerät gegen einen geräteseitigen Index; um diesen Index aufzubauen, sendet das Gerät automatisch den extrahierten Text und die KI-Beschreibung jedes indexierten Dokuments, in Passagen aufgeteilt, jeweils mit einer Kopfzeile aus Titel, Typ und Datum des Dokuments, an den Modellanbieter, der daraus die auf dem Gerät gespeicherten Suchvektoren berechnet; bei einer Suche wird nur die Suchanfrage gesendet, bei einer Chat-Frage nur die Frage und die vom Gerät ausgewählten Textpassagen; verwaltete KI ist der einzige KI-Weg dieser Version, eine Mitbring-Funktion für eigene API-Schlüssel ist nicht Bestandteil dieser Version (Abschnitt 6 der AGB); Dokumentinhalte und Suchpassagen erreichen auf diesem Weg zu keinem Zeitpunkt den eigenen Server von Scandora — Scandora stellt lediglich die kurzlebige Zugangsberechtigung aus —, und die daraus resultierende KI-Anfrage unterfällt diesem Vertrag; Scandora betreibt weder ein serverseitiges KI-Gateway noch einen serverseitig gehosteten Suchindex; einzige Ausnahme ist der optionale Weg zu KI-Modellen außerhalb der EU: Hat ein Nutzer des Verantwortlichen „KI-Modelle außerhalb der EU“ eingeschaltet, kann eine KI-Anfrage stattdessen vom Gerät über den Server von Scandora in Deutschland, der sie nur im Arbeitsspeicher hält und weder speichert noch protokolliert, an Anthropic in den USA gehen (Anlage 1); (b) Cloud-Verlaufssynchronisation — Speicherung des Verlaufseintrags jedes abgeschlossenen Scans auf dem eigenen Server von Scandora in Falkenstein,

Deutschland, damit der Verlauf auf allen Geräten des Verantwortlichen verfügbar ist; (c) serverseitiger DATEV-Export (in Vorbereitung; für die Tarife Business und Enterprise vorgesehen und noch nicht freigeschaltet, sodass auf diesem Weg derzeit keine Daten fließen) — Übermittlung der exportierten Buchungssätze (je Buchung Datum, Bruttobetrag, Soll-/Haben-Kennzeichen, Konto und Gegenkonto, DATEV-BU-Schlüssel, Rechnungsnummer, Buchungstext, Erkennungs-Konfidenzwert, Dokumentdateiname) samt Exportkopf (Berater- und Mandantennummer, Kontenrahmen, Beginn des Wirtschaftsjahres, exportierter Zeitraum, Name der exportierenden Person) und der dazugehörigen Dokumentbilder an den eigenen Server von Scandora in Falkenstein, Zusammenstellung der DATEV-EXTF-ZIP-Datei und Rückgabe an den Verantwortlichen, ohne Speicherung von Buchungssätzen oder Bildern; (d) GoBD-Erfassungs- und Änderungsaufzeichnungen — solange die für den Verantwortlichen handelnde Person angemeldet ist, schreibt jede Erfassung, jede Metadatenänderung, jeder Export und jede Löschung einen Datensatz auf denselben Server: einen Erfassungsnachweis (SHA-256-Prüfsumme der erfassten Datei, Erfassungsquelle, Gerätebeschreibung, Nutzer- und Profilkennung, Server-Zeitstempel) und einen Änderungsprotokolleintrag (Dokumentkennung, Ereignisart — Erfassung, Bearbeitung, Export oder Löschung —, Nutzerkennung, handelndes Profil, Server-Zeitstempel, bei einem Export das gewählte Exportziel und, bei einer Bearbeitung, der alte und der neue Wert jedes geänderten Metadatenfeldes); löscht der Server von Scandora Verlaufseinträge selbst — nach Ablauf der unten genannten Speicherdauer oder auf Veranlassung des Verantwortlichen, weil sie mit einem nicht mehr wiederherstellbaren Schlüssel des Erweiterten Schutzes gesperrt sind —, schreibt er je gelöschtem Eintrag einen Änderungsprotokolleintrag, auch während niemand angemeldet ist, mit Dokumentkennung, Ereignisart Löschung, Nutzerkennung und Zeitpunkt der Löschung, aber ohne handelndes Profil und ohne Feldwerte; keiner der beiden Datensätze enthält ein Seitenbild oder den Dokumenttext, und beide werden in jedem Tarif geschrieben, ohne dass dies abwählbar wäre; (e) geräteübergreifendes Importregister — importiert der Verantwortliche ein Dokument aus einem verbundenen Cloud-Speicher (Google Drive, Dropbox, OneDrive, Nextcloud, Trello) oder über die Dateiauswahl des Geräts, hält Scandora diesen Import zentral fest, damit ein zweites Gerät dieselbe Datei nicht erneut importiert; dieser Datensatz liegt als einziger nicht auf dem eigenen Server von Scandora, sondern in Google Firestore in der Region europe-west3 (Frankfurt), und enthält die Quellidentität (Anbieter, Kennung des Quellkontos, Dateikennung und Versionsmarke des Anbieters oder, bei einer über die Dateiauswahl gewählten Datei, einen SHA-256-Fingerabdruck ihres Inhalts), Konto- und Profilkennung, den Importstatus, Status und Speicherreferenz je Ziel sowie eine kurzlebige Gerätereservierung — kein Seitenbild und keinen Dokumenttext, während die Speicherreferenz die Datei-URL des Ziels oder der Dateipfad der erzeugten PDF ist und daher den Dateinamen des Dokuments enthalten kann; er wird in jedem Tarif bei jedem Import geschrieben, ein erneuter Import derselben Datei entfernt ihn, und die Kontolöschung löscht sämtliche Einträge des Kontos. Nimmt Scandora später einen weiteren Weg hinzu, auf dem Dokumentinhalte des Verantwortlichen in dessen Auftrag verarbeitet werden, informiert Scandora ihn vor dem Wirksamwerden in Textform und passt die Abschnitte 3 und 6 entsprechend an; der Verantwortliche kann vor dem Wirksamwerden widersprechen. Widerspricht er, wird der neue Weg für sein Konto nicht

freigeschaltet und dieser Vertrag gilt für die oben genannten Wege unverändert fort; kann Scandora die Leistung ohne diesen Weg nicht erbringen, teilt Scandora dies auf den Widerspruch hin mit, und der Verantwortliche kann diesen Vertrag und den zugrunde liegenden Vertrag zu dem Zeitpunkt kündigen, zu dem die Erweiterung wirksam geworden wäre. Widerspricht er nicht, gilt dieser Vertrag ab diesem Zeitpunkt auch für den neuen Weg. Die Verarbeitung dauert an, solange der Verantwortliche Scandora nutzt, und endet mit Beendigung des zugrunde liegenden Vertrags.

Speicherdauer: Im Free-Tarif wird jeder Verlaufseintrag 180 Tage nach seiner Speicherung gelöscht; in einem kostenpflichtigen Tarif wird kein Eintrag gelöscht, solange das Abonnement läuft, und die Frist beginnt mit dessen Ende — 90 Tage (Pro) bzw. 180 Tage (Business). Wird innerhalb dieser Frist erneut ein Abonnement abgeschlossen, bleiben die Einträge erhalten. Einträge, die bei der Aktivierung dieser Löschung bereits gespeichert waren, laufen ab diesem Aktivierungsdatum. Ein gelöschter Eintrag wird mit der Löschung entfernt, bei Kontolöschung werden sämtliche Einträge des Kontos mitgelöscht, spätestens innerhalb von 30 Tagen. Der stillgelegte Opt-in-KI-Suchindex nimmt keine neuen Daten mehr auf — die Suche läuft stattdessen auf dem Gerät (Abschnitt 1). Verbliebene Daten aus der Zeit vor dieser Umstellung werden innerhalb von 30 Tagen nach Kontolöschung gelöscht und, soweit keine andere Frist gilt, nach 30 Tagen ohne Kontoaktivität. Der Importregistereintrag wird für die Dauer des Kontos aufbewahrt; ein erneuter Import derselben Datei löscht ihn, und die Kontolöschung löscht sämtliche Einträge des Kontos.

Die GoBD-Erfassungs- und Änderungsaufzeichnungen werden weder beim Löschen des zugehörigen Verlaufseintrags noch bei Kontolöschung entfernt. Was eine Kontolöschung sehr wohl bewirkt, ist die Ersetzung der Kennungen darin: Nutzer- und Profilkennung werden durch eine Ersatzkennung ersetzt, und die geänderten Metadatenwerte sowie die Namen exportierter Dateien werden mit dem Konto entfernt; Prüfsumme, Zeitstempel und Hash-Verkettung bleiben erhalten, sodass die Aufzeichnungen ohne die Kennungen fortbestehen, mit denen sie geschrieben wurden. Das Ergebnis gibt Scandora nicht als anonyme Daten aus: Der Verkettungs-Fingerabdruck jedes Eintrags wurde vor dieser Ersetzung berechnet, und die Prüfsumme des Erfassungsnachweises passt weiterhin zum Dokument selbst; wer dieses Dokument oder die ersetzten Kennungen besitzt, kann einen Eintrag daher weiterhin einer Person zuordnen. Kein deutsches Gesetz verpflichtet Scandora zur Aufbewahrung dieser Aufzeichnungen. Die Aufzeichnungs- und Unveränderbarkeitspflichten nach den GoBD (§ 146 Abs. 4, § 147 AO, § 239 Abs. 3 HGB) treffen den Verantwortlichen bzw. sein Unternehmen, nicht Scandora, und § 257 HGB bindet Kaufleute, was Scandora — betrieben als nicht im Handelsregister eingetragenes Kleingewerbe — nicht ist. Scandora stützt sich daher nicht auf Art. 28 Abs. 3 lit. g DSGVO, der dem Auftragsverarbeiter eine Aufbewahrung über das Vertragsende hinaus nur dort erlaubt, wo das Unionsrecht oder das Recht eines Mitgliedstaats die Speicherung vorschreibt. Scandora bewahrt diese Aufzeichnungen zum eigenen Nachweiszweck auf und ist für diese Aufbewahrung Verantwortlicher (Art. 6 Abs. 1 lit. f DSGVO): Ein mit Scandora erfasstes Dokument soll so lange überprüfbar bleiben, wie der Verantwortliche es vorlegen müssen könnte. Sie werden in jedem Tarif geschrieben und lassen sich nicht abschalten; Scandora stellt diese Aufbewahrung daher nicht als Weisung des Verantwortlichen dar. Scandora bewahrt beide Aufzeichnungen zehn Jahre auf — die Frist, die das deutsche

Recht für die eigenen Bücher und Aufzeichnungen eines Gewerbetreibenden vorsieht (§ 147 Abs. 1 Nr. 1, Abs. 3 AO) —, gerechnet ab dem Schluss des Kalenderjahres, in dem die Aufzeichnung entstanden ist (§ 147 Abs. 4 AO), und löscht sie nach deren Ablauf. Diese Frist ist eine von Scandora selbst gesetzte Obergrenze und keine Scandora treffende Speicherpflicht; Abschnitt 11 der Datenschutzerklärung sagt dasselbe. Die Lösch- oder Rückgabepflicht aus Abschnitt 5 erfasst diese beiden Aufzeichnungen während dieser Frist nicht. Eine Einschränkung, offen gesagt: Heute entfernt nichts diese Datensätze nach Fristablauf — das Änderungsprotokoll ist auf Datenbankebene reine Anfügung, seine Einträge lassen sich überhaupt nicht löschen, und noch keine Routine löscht die Erfassungsnachweise nach Fristablauf; diesen Löschschritt zu bauen, steht auf der Liste von Scandora. Endet die Aufbewahrungspflicht des Verantwortlichen früher, teilt er dies in Textform mit; Scandora nutzt die Aufzeichnungen dann ausschließlich zu diesem Nachweiszweck (Art. 18 DSGVO) und vermerkt einen Widerspruch (Art. 21 DSGVO). Eine frühere Löschung sagt Scandora nicht zu, weil sie technisch nicht ausführbar ist. Die Datenbank weist jede Löschung eines Änderungsprotokolleintrags zurück und jede Änderung daran mit einer einzigen Ausnahme: einer Änderung, die die Kontolöschungs-Kennzeichnung von Scandora trägt, die Verkettungswerte und die Zeitstempel unangetastet lässt und den Eintrag als geschwärzt kennzeichnet — diese Kennzeichnung setzt allein die Kontolöschungs-Routine, und ein so gekennzeichneter Eintrag wird nicht mehr gegen seinen eigenen Fingerabdruck geprüft. Prüfsumme und Zeitstempel des Erfassungsnachweises sind einmalig beschreibbar; ein einzelner Eintrag lässt sich daher weder berichtigen noch löschen (siehe Abschnitt 9).

2. Art und Zweck der Verarbeitung

Auf dem Managed-AI-Pfad: Das Gerät sendet Dokumentbilder, extrahierten Text, Prompts, Suchanfragen sowie, für den Chat, die auf dem Gerät ausgewählten Textpassagen sowie, wenn ein Dokument für die Suche indexiert wird, dessen extrahierten Text und KI-Beschreibung, in Passagen aufgeteilt, jeweils mit einer Kopfzeile aus Titel, Typ und Datum des Dokuments, direkt an den KI-Modellanbieter, unter Verwendung der in Abschnitt 1 beschriebenen kurzlebigen Zugangsberechtigung; der Server von Scandora erhält oder speichert diese Inhalte zu keinem Zeitpunkt, auch nicht vorübergehend; der Modellanbieter verarbeitet sie, um KI-Analyseergebnisse zu erzeugen (z. B. Titel, Labels, extrahierte Felder, die Suchvektoren des geräteseitigen Index, Antworten bei Suche und Chat), und bewahrt sie, abgesehen von der unten beschriebenen Missbrauchsüberwachung, ebenfalls nicht über die Anfrage hinaus auf. Auf dem optionalen Weg zu KI-Modellen außerhalb der EU: vorübergehende Verarbeitung auf dem Server von Scandora in Deutschland, nur im Arbeitsspeicher und ohne Speicherung oder Protokollierung, um die Anfrage an Anthropic in den USA weiterzuleiten und die Antwort zurückzugeben; Anthropic nutzt die Inhalte nur, um die Antwort zu erzeugen, trainiert damit keine Modelle und löscht sie innerhalb von 30 Tagen (markierte Anfragen bis zu 2 Jahre). Auf dem Weg der Cloud-Verlaufssynchronisation: dauerhafte Speicherung der in Abschnitt 3 genannten Daten zum Zweck der geräteübergreifenden Verlaufssynchronisation. Auf dem Weg des serverseitigen DATEV-Exports (in Vorbereitung, siehe Abschnitt 1): vorübergehende Verarbeitung der Buchungssätze und der dazugehörigen Dokumentbilder zur Erstellung der DATEV-EXTF-ZIP-Datei ohne Speicherung. Auf dem Weg der GoBD-Aufzeichnungen: dauerhafte

Speicherung des Erfassungsnachweises und des Änderungsprotokolleintrags zum Nachweis, dass eine erfasste Datei unverändert ist und jede spätere Änderung an ihren Metadaten nachvollziehbar bleibt. Auf dem Weg des Importregisters: Speicherung eines Registereintrags je Import in Google Firestore (Frankfurt), damit dieselbe Quelldatei nicht auf mehreren Geräten doppelt importiert wird. Prompts, die über die verwaltete KI gesendet werden und die Googles automatische Sicherheitssysteme markieren, kann Google bis zu 90 Tage lang in der für die verwaltete KI genutzten Google-Cloud-Region (europe-west3, Frankfurt) speichern, ausschließlich zur Missbrauchsüberwachung; Google nutzt sie nicht zum Trainieren von Modellen.

3. Art der personenbezogenen Daten

Dokumentbilder und der daraus extrahierte Text sowie die Prompts und Fragen zu einem Dokument, die Suchanfragen und, für den Chat, die auf dem Gerät ausgewählten Textpassagen sowie, wenn ein Dokument für die Suche indexiert wird, dessen extrahierter Text und KI-Beschreibung, in Passagen aufgeteilt, jeweils mit einer Kopfzeile aus Titel, Typ und Datum des Dokuments — vom Gerät direkt an den Modellanbieter gesendet, nicht an Scandora (verwaltete KI, EU-Weg); auf dem optionalen Weg zu KI-Modellen außerhalb der EU Seitenbilder oder Text des gewählten Dokuments, die Frage und die Antwort des Modells — über den Server von Scandora in Deutschland (nur Arbeitsspeicher, keine Speicherung) an Anthropic in den USA gesendet; der auf dem eigenen Server von Scandora gespeicherte Verlaufseintrag mit dem vollständigen aus dem Dokument extrahierten Text (OCR-Text, gespeichert bis zu einer Obergrenze von 400.000 Zeichen), einem kleinen Base64-Vorschaubild der ersten Seite und den Metadaten des Eintrags (Titel, Erstellungsdatum, Seitenzahl, Dateigröße, Labels, gewählte Exportziele sowie von der KI extrahierte Felder wie Betrag, Rechnungsnummer und Rechnungsdatum); die Daten eines DATEV-Exports (vorübergehend; der Export ist in Vorbereitung und noch nicht freigeschaltet): die Buchungssätze (je Buchung Datum, Bruttobetrag, Soll-/Haben-Kennzeichen, Konto und Gegenkonto, DATEV-BU-Schlüssel, Rechnungsnummer, Buchungstext, Erkennungs-Konfidenzwert, Dokumentdateiname), der Exportkopf (Beraternummer, Mandantennummer, Kontenrahmen, Beginn des Wirtschaftsjahres, exportierter Zeitraum, Name der exportierenden Person) und die dazugehörigen Dokumentbilder; sowie die GoBD-Erfassungs- und Änderungsaufzeichnungen: je Erfassung eine SHA-256-Prüfsumme der erfassten Datei, die Erfassungsquelle (Kamera, Netzwerkscanner oder Datei-Upload), eine Gerätebeschreibung, die Nutzer- und Profilkennung und ein Server-Zeitstempel; je Dokumentereignis die Dokumentkennung, die Ereignisart (Erfassung, Bearbeitung, Export, Löschung), die Nutzerkennung, das handelnde Profil (nicht bei einer Löschung, die der Server von Scandora selbst vornimmt, siehe Abschnitt 1), ein Server-Zeitstempel, bei einem Export das gewählte Exportziel und, bei einer Bearbeitung, der alte und der neue Wert jedes geänderten Metadatenfeldes (Titel, Labels, Bruttobetrag, Rechnungsnummer, Rechnungsdatum) — kein Seitenbild und kein Dokumenttext; sowie der Importregistereintrag: Quellanbieter, Kennung des Quellkontos, Dateikennung und Versionsmarke des Anbieters oder — bei einer über die Dateiauswahl gewählten Datei — ein SHA-256-Fingerabdruck ihres Inhalts, Konto- und Profilkennung, Importstatus, Status und Speicherreferenz je Ziel sowie eine kurzlebige Gerätereservierung, ohne Seitenbild und ohne Dokumenttext; die Speicherreferenz ist die Datei-URL des Ziels

oder der Dateipfad der erzeugten PDF und kann daher den Dateinamen des Dokuments enthalten. Diese Daten können besondere Kategorien personenbezogener Daten (Art. 9 DSGVO) enthalten, soweit der Verantwortliche solche Dokumente übermittelt.

4. Kategorien betroffener Personen

Vom Verantwortlichen bestimmte Personen, deren Daten in den verarbeiteten Dokumenten enthalten sind (z. B. Mandanten, Kunden, Mitarbeitende).

5. Pflichten des Auftragsverarbeiters

Verarbeitung nur auf dokumentierte Weisung des Verantwortlichen, es sei denn, Scandora ist nach dem Unionsrecht oder dem Recht eines Mitgliedstaats, dem Scandora unterliegt, zu einer anderen Verarbeitung verpflichtet; in diesem Fall teilt Scandora dem Verantwortlichen diese rechtliche Anforderung vor der Verarbeitung mit, sofern das betreffende Recht diese Mitteilung nicht wegen eines wichtigen öffentlichen Interesses verbietet (Art. 28 Abs. 3 lit. a DSGVO); unverzügliche Information des Verantwortlichen, wenn eine Weisung nach Auffassung von Scandora gegen die DSGVO oder andere Datenschutzbestimmungen der Union oder der Mitgliedstaaten verstößt (Art. 28 Abs. 3 Unterabs. 2 DSGVO); Vertraulichkeitsverpflichtung der zur Verarbeitung befugten Personen; Umsetzung der technischen und organisatorischen Maßnahmen (Abschnitt 8); Unterstützung bei Betroffenenrechten und bei den Pflichten nach Art. 32–36 DSGVO; Löschung oder Rückgabe der Daten nach Wahl des Verantwortlichen bei Vertragsende (Art. 28 Abs. 3 lit. g DSGVO); die GoBD-Erfassungs- und Änderungsaufzeichnungen nach Abschnitt 1 fallen nicht unter diese Pflicht: Scandora bewahrt sie als Verantwortlicher zum eigenen Nachweiszweck für die dort genannte, von Scandora selbst gesetzte Zehnjahresfrist auf — keine Scandora treffende Speicherpflicht — und das Änderungsprotokoll lässt sich überdies überhaupt nicht Eintrag für Eintrag löschen; Bereitstellung der zur Nachweisführung erforderlichen Informationen sowie Duldung und Unterstützung von Überprüfungen, einschließlich Inspektionen, durch den Verantwortlichen oder einen von ihm beauftragten Prüfer (Art. 28 Abs. 3 lit. h DSGVO).

6. Unterauftragsverarbeiter

Der Verantwortliche genehmigt den Einsatz der unten gelisteten Unterauftragsverarbeiter für die in Abschnitt 1 beschriebene Verarbeitung. Für die Verarbeitung, die Scandora als Auftragsverarbeiter durchführt, ist die Anlage 1 dieses Vertrags maßgeblich. Abschnitt 7 der Datenschutzerklärung von Scandora (https://scandora.eu/privacy.html) verfolgt einen anderen Zweck: Er listet sämtliche Empfänger personenbezogener Daten auf, einschließlich der Anbieter, die Scandora als Verantwortlicher für eigene Zwecke einsetzt; soweit beide denselben Anbieter beschreiben, gilt für die auftragsverarbeitende Seite dieser Vertrag. Scandora informiert über beabsichtigte Änderungen und räumt ein Widerspruchsrecht ein. Scandora erlegt jedem Unterauftragsverarbeiter dieselben Datenschutzpflichten auf, die in diesem Vertrag festgelegt sind (Art. 28 Abs. 4 DSGVO).

7. Drittlandübermittlung

Soweit Unterauftragsverarbeiter Daten außerhalb der EU/EWR (z. B. USA) verarbeiten, erfolgt dies auf Grundlage der EU-Standardvertragsklauseln und/oder einer Zertifizierung unter dem EU-US Data Privacy Framework. Die nach diesem Vertrag gespeicherten Daten verbleiben auf den eigenen Servern von Scandora in Falkenstein, Deutschland, mit einer Ausnahme: Das geräteübergreifende Importregister wird in Google Cloud Firestore in der Region europe-west3 (Frankfurt) gespeichert. Beide Orte liegen in Deutschland, sodass keiner der beiden Speicher eine Drittlandübermittlung ist; für die übrige Google-Cloud-Verarbeitung um diesen Speicher herum gelten die EU-Standardvertragsklauseln und/oder die DPF-Zertifizierung von Google. Auf dem EU-Weg (Standard) wird die verwaltete KI vom Gerät direkt angefragt, mit einer vom Server von Scandora ausgestellten kurzlebigen Zugangsberechtigung; der KI-Aufruf selbst wird in Deutschland verarbeitet, wenn der Frankfurter Regionaldienst (Vertex AI europe-west3) genutzt wird, ist für diesen Schritt keine Drittlandübermittlung und läuft zu keinem Zeitpunkt über den eigenen Server von Scandora. Der optionale Weg zu KI-Modellen außerhalb der EU, nur wenn ein Nutzer des Verantwortlichen ihn eingeschaltet hat, ist eine Drittlandübermittlung: Die Anfrage läuft über den Server von Scandora in Deutschland an Anthropic, das sie in den USA verarbeitet, auf Grundlage der EU-Standardvertragsklauseln (Module 2 und 3) im Auftragsverarbeitungsvertrag von Anthropic, mit den Zusätzen für das Vereinigte Königreich und die Schweiz; Anthropic ist nicht nach dem EU-US Data Privacy Framework zertifiziert.

8. Technische und organisatorische Maßnahmen (TOM)

Verschlüsselung in der Übertragung (TLS) auf jeder Verbindung zwischen App, den Servern von Scandora und den Unterauftragsverarbeitern; Verschlüsselung hinterlegter Integrations- und KI-Zugangsdaten pro Nutzer (AES-256-GCM), während für die übrigen nach diesem Vertrag gespeicherten Daten keine Verschlüsselung im Ruhezustand als Maßnahme angeführt wird; rollenbasierte Zugriffskontrolle und Protokollierung; Pseudonymisierung der Nutzerkennung (Firebase-UID); auf dem EU-Weg (Standard) wird die verwaltete KI vom Gerät direkt mit einer kurzlebigen Zugangsberechtigung angefragt, der Server von Scandora erhält oder speichert die Dokumentinhalte auf diesem Weg zu keinem Zeitpunkt; auf dem optionalen Weg zu KI-Modellen außerhalb der EU hält der Server von Scandora die Inhalte nur für die Dauer der Anfrage im Arbeitsspeicher und speichert oder protokolliert sie nicht; Trennung gespeicherter Einträge je Nutzer und Profil, lesbar nur mit dem authentifizierten Token dieses Nutzers; das Löschen eines Verlaufseintrags entfernt ihn, und die Kontolöschung löscht sämtliche Verlaufseinträge und sämtliche Importregistereinträge des Kontos, während die GoBD-Erfassungs- und Änderungsaufzeichnungen nach Abschnitt 1 aufbewahrt und von dieser Löschung nicht erfasst werden — die Kontolöschung ersetzt stattdessen die Kennungen darin, sodass kein aufbewahrter Eintrag mehr die Kennungen des gelöschten Kontos enthält; Hosting der OAuth-Komponenten, des Endpunkts zur Ausstellung der Zugangsberechtigung sowie sämtlicher nach diesem Vertrag gespeicherter Daten auf dem eigenen Server von Scandora in Falkenstein, Deutschland, mit zwei in Deutschland verbleibenden Ausnahmen: Der KI-Modellaufruf auf dem EU-Weg geht in die Google-Region europe-west3 (Frankfurt), und

das Importregister wird in Google Cloud Firestore in derselben Region gespeichert; auf dem optionalen Weg zu KI-Modellen außerhalb der EU geht der KI-Modellaufruf über den Server von Scandora an Anthropic in den USA (Abschnitt 7); regelmäßige Updates, Wiederherstellbarkeit und Belastbarkeit der Systeme; Verfahren zur regelmäßigen Überprüfung der Wirksamkeit der Maßnahmen.

9. Rechte des Verantwortlichen / der betroffenen Personen

Der Verantwortliche bleibt Herr der Daten. Betroffene Personen haben die Rechte aus Art. 15–22 DSGVO (Auskunft, Berichtigung, Löschung, Einschränkung, Datenübertragbarkeit, Widerspruch). Scandora unterstützt den Verantwortlichen bei deren Erfüllung. Für die GoBD-Erfassungs- und Änderungsaufzeichnungen nach Abschnitt 1 ist diese Unterstützung durch deren reine Anfügung begrenzt: Auskunft (Art. 15), Einschränkung der weiteren Verwendung (Art. 18), Herausgabe der Einträge (Art. 20) und der Vermerk eines Widerspruchs (Art. 21) sind möglich; die Berichtigung (Art. 16) oder Löschung (Art. 17) eines einzelnen Eintrags während der in Abschnitt 1 genannten, von Scandora selbst gesetzten Aufbewahrungsfrist ist es nicht; wie dort offen dargelegt, entfernt sie heute auch nach Fristablauf nichts. Die Kontolöschung ersetzt die Kennungen in jedem Eintrag des Kontos, die Einträge bleiben aber personenbezogene Daten.

10. Schlussbestimmungen

Maßgeblich ist die deutsche Fassung. Es gilt deutsches Recht. Sollten einzelne Bestimmungen unwirksam sein, bleibt der übrige Vertrag wirksam.

Anlage 1 — Unterauftragsverarbeiter / Annex 1 — Sub-Processors

Anbieter / Provider	Zweck / Purpose	Region
Hetzner Online GmbH	Hosting des eigenen EU-Servers: Verlaufsspeicher, Zusammenstellung des DATEV-Exports (in Vorbereitung) sowie GoBD-Erfassungs- und Änderungsaufzeichnungen / hosting of Scandora's own EU server: history store, DATEV export assembly (coming soon) and the GoBD capture and change records	Deutschland (Falkenstein) / Germany (Falkenstein)
Google (Gemini API / Vertex AI)	KI-Dokumentanalyse, Suche und Chat (Modellanbieter) — vom Gerät direkt angefragt mit einer vom Server von Scandora ausgestellten kurzlebigen Zugangsberechtigung / AI document analysis, search and chat (model provider) — called directly by the device using a short-lived credential Scandora's server issues	Deutschland (Frankfurt) — Vertex AI europe-west3 für KI-Analyse, Suche und Chat, vom Gerät direkt angefragt; Prompts, die Googles automatische Sicherheitssysteme markieren, kann Google bis zu 90 Tage lang in dieser Region speichern, ausschließlich zur Missbrauchsüberwachung (Abschnitt 2); übrige Google-Cloud-Verarbeitung (u. a. Kontrollebene/Support) auf Grundlage der EU-Standardvertragsklauseln / des DPF / Germany (Frankfurt) — Vertex AI europe-west3 for AI analysis, search and chat, called directly by the device; Google may keep prompts its automated safety systems flag for up to 90 days, in that region, only for abuse monitoring (section 2); remaining Google Cloud processing (incl. control plane/ support) on the basis of the EU Standard Contractual Clauses / DPF

Anthropic Ireland, Limited (Dublin), mit Anthropic, PBC (USA) und deren Cloud-Anbietern — optional: nur, wenn Ihr Nutzer „KI-Modelle außerhalb der EU“ eingeschaltet hat / Anthropic Ireland, Limited (Dublin), with Anthropic, PBC (USA) and its cloud providers — optional: used only when your user has turned on “AI models outside the EU”	KI-Dokumentanalyse und Chat mit Claude-Modellen, über den Server von Scandora in Deutschland (nur Arbeitsspeicher, keine Speicherung) — Seitenbilder oder Text des gewählten Dokuments, die Frage, die Antwort des Modells (vorübergehend; Löschung durch Anthropic innerhalb von 30 Tagen, markierte Anfragen bis zu 2 Jahre; kein Training) / AI document analysis and chat with Claude models, through Scandora's server in Germany (memory only, not stored) — page images or text of the chosen document, the question, the model's answer (transient; deleted by Anthropic within 30 days, flagged requests up to 2 years; no training)	USA — EU-Standardvertragsklauseln Module 2/3 im AVV von Anthropic (UK- und Schweiz-Zusatz) / USA — EU SCCs Modules 2/3 in Anthropic's DPA (UK and Swiss addenda)
Google (Firebase / Cloud Firestore)	Speicherung des geräteübergreifenden Importregisters (keine Dokumentinhalte) / storage of the cross-device import register (no document content)	Deutschland (Frankfurt) — Firestore-Region europe-west3; übrige Google-Cloud-Verarbeitung (u. a. Kontrollebene/Support) auf Grundlage der EU-Standardvertragsklauseln / des DPF / Germany (Frankfurt) — Firestore region europe-west3; remaining Google Cloud processing (incl. control plane/ support) on the basis of the EU Standard Contractual Clauses / DPF

English version (courtesy translation)

Data Processing Agreement (DPA) pursuant to Art. 28 GDPR

This agreement sets out the data-protection obligations of the parties for the processing of personal data that Scandora performs as a processor on behalf of the controller. It supplements Scandora's Terms of Service and Privacy Policy.

Note: the controller's own account data (email address, name, subscription and billing record) and email correspondence with Scandora sit outside this DPA; for those Scandora is the controller under its own contract with the customer. The history record, by contrast, is covered by this agreement in full — the extracted document text, the preview thumbnail and the record's metadata: the controller decides which documents are scanned and why they are kept, so Scandora stores the record as processor and uses it for no purpose of its own. Section 8 of Scandora's Privacy Policy lists history metadata under Scandora's controller role; that describes use without a DPA, where the user is a data subject rather than a controller.

1. Subject and Duration

The subject is the processing of the controller's document content on five paths: (a) managed AI — for document analysis and for document search and chat, the device running Scandora asks the AI model provider directly, using a short-lived credential (up to 30 minutes) that Scandora's server issues; retrieval for search and chat runs on the device against an on-device index; to build that index, the device automatically sends the extracted text and the AI description of each indexed document, split into passages each headed by the document's title, type and date, to the model provider, which returns the search vectors kept on the device; for a search, only the search query is sent, and for a chat question, only the question and the passages the device selects; managed AI is the only AI path in this version, a bring-your-own-API-key option is not part of this version (section 6 of the Terms); document content and search passages never reach Scandora's own server on this path — Scandora only issues the short-lived credential — and the resulting AI request is covered by this agreement; Scandora does not operate a server-side AI gateway or a server-hosted search index; the one exception is the optional route to AI models outside the EU: where a user of the controller has turned on “AI models outside the EU”, an AI request can instead go from the device through Scandora's server in Germany, which holds it in memory only and neither stores nor logs it, to Anthropic in the USA (Annex 1); (b) cloud history sync — storing each completed scan's history record on Scandora's own server in Falkenstein, Germany, so that the history is available on all of the controller's devices; (c) server-side DATEV export (coming soon; designed for the Business and Enterprise plans and not yet switched on, so no data travels this path yet) — sending the exported booking rows (per booking the date, gross amount, debit/credit marker, account and contra account, DATEV BU key, invoice number, booking text, recognition confidence and document file name) together with the export header (Berater and Mandant number, chart of accounts, fiscal-year start, exported date range, the name set as the exporting user)

and the document images attached to those bookings to Scandora's own server in Falkenstein, assembling the DATEV EXTF ZIP there and returning it to the controller, without storing the rows or the images; (d) GoBD capture and change records — while the person acting for the controller is signed in, every capture, metadata edit, export and deletion writes a record to the same server: a capture record (SHA-256 checksum of the captured file, capture source, device description, user and profile identifier, server timestamp) and a change-log entry (document identifier, event type — capture, edit, export or delete —, user identifier, acting profile, server timestamp, for an export the chosen destination and, for an edit, the old and the new value of each metadata field that changed); where Scandora's server deletes history records itself — once the retention period below has run out, or at the controller's request because they are locked with an Advanced Protection key that can no longer be recovered — it writes one change-log entry per deleted record, also while nobody is signed in, with the document identifier, the event type delete, the user identifier and the time of the deletion, but no acting profile and no field values; neither record holds a page image or the document text, and both are written on every plan, with no way to switch them off; (e) cross-device import register — where the controller imports a document from a connected cloud storage (Google Drive, Dropbox, OneDrive, Nextcloud, Trello) or from the device's file picker, Scandora records that import centrally so a second device cannot import the same file again; this record is the only one not held on Scandora's own server but in Google Firestore in the europe-west3 (Frankfurt) region, and it carries the source identity (provider, an identifier of the source account, the provider's file identifier and version marker or, for a file picked on the device, a SHA-256 fingerprint of that file's content), the account and profile identifier, the import status, the status and storage reference of each destination and a short-lived device lease — no page image and no document text, while the storage reference is the destination's file URL or the generated PDF's file path and can therefore contain the document's file name; it is written on every plan on every import, importing the same file again removes it, and account deletion erases every entry of the account. If Scandora later adds a further path on which the controller's document content is processed on the controller's behalf, Scandora informs the controller in text form before that extension takes effect and updates sections 3 and 6 accordingly; the controller may object before it takes effect. If the controller objects, the new path is not activated for that account and this agreement continues unchanged for the paths listed above; where Scandora cannot provide the service without that path, Scandora says so in answer to the objection and the controller may terminate this agreement and the underlying contract with effect from the date the extension would have taken effect. If the controller does not object, this agreement covers the new path from that date. Processing lasts for as long as the controller uses Scandora and ends when the underlying contract ends.

Retention: on the Free plan each history record is erased 180 days after it was stored; on a paid plan no record is erased while the subscription is running, and the window starts when the subscription ends — 90 days (Pro), 180 days (Business). A subscription taken up again inside that window leaves the records in place. Records that were already stored when this deletion was switched on run their window from that switch-on date. A record the controller deletes is erased with that deletion, and on account deletion every record of the account is erased with it, at the latest within 30 days. The retired opt-in AI search index

no longer accepts new data — search now runs on the device instead (section 1). Any data that remained in it from before this change is erased within 30 days of account deletion, and, where no other retention period applies, after 30 days without account activity. The import-register entry is kept for the life of the account; importing the same file again deletes it, and account deletion erases every entry of the account.

The GoBD capture and change records are not removed when the corresponding history record is deleted, nor on account deletion. What an account deletion does do is replace the identifiers in them: the user and profile identifiers are replaced by a stand-in value, and the edited metadata values and the exported file names are removed with the account, while the checksum, the timestamps and the hash chain stay, so the records survive without the identifiers they were written with. Scandora does not present the result as anonymous data: each entry's chain fingerprint was computed before that replacement, and the capture record's checksum still matches the document itself, so anyone holding that document or the replaced identifiers can still tie an entry to a person. No German law requires Scandora to store these records. The GoBD record-keeping and unalterability duties (§ 146(4), § 147 AO, § 239(3) HGB) bind the controller or its business, not Scandora, and § 257 HGB binds merchants, which Scandora — run as an unregistered sole proprietorship (Kleingewerbe) — is not. Scandora therefore does not rely on Art. 28(3)(g) GDPR, which lets a processor keep data past the end of the contract only where Union or Member State law requires that storage. Scandora keeps these records for its own evidence purpose and is the controller for that retention (Art. 6(1)(f) GDPR): a document captured with Scandora should stay verifiable for as long as the controller may have to produce it. They are written on every plan and cannot be switched off; Scandora therefore does not present that retention as an instruction given by the controller. Scandora keeps both records for ten years, the period German law sets for a trader's own books and records (§ 147(1) No. 1, (3) AO), counted from the end of the calendar year in which the record was made (§ 147(4) AO), and deletes them once that period has expired. That period is a cap Scandora sets itself, not a storage duty imposed on it; section 11 of the privacy policy says the same. The delete-or-return duty in section 5 does not reach these two records while that period runs. One limitation, stated plainly: today nothing removes these rows by age — the change log is append-only at database level, so its entries cannot be deleted at all, and no routine yet deletes the capture records when the period expires; building that deletion step is on Scandora's list. Where the controller's own retention duty ends earlier, the controller says so in text form; Scandora then uses the records for that evidence purpose only (Art. 18 GDPR) and notes an objection (Art. 21 GDPR). Scandora does not promise an earlier erasure, because it cannot be carried out. The database rejects every deletion of a change-log entry, and every change to one except a change that carries Scandora's account-deletion marker, leaves the chain values and the timestamps untouched and marks the entry as redacted — only the account-deletion routine sets that marker, and a marked entry is no longer checked against its own fingerprint. The capture record's checksum and timestamp are write-once, so a single entry can be neither rectified nor erased (see section 9).

2. Nature and Purpose of Processing

On the managed AI path: the device sends document images, extracted text, prompts, search queries and, for chat, the on-device-selected passages, and, when a document is indexed for search, its extracted text and AI description, split into passages each headed by the document's title, type and date, directly to the AI model provider, using the short-lived credential described in section 1; Scandora's server never receives or stores that content, even transiently; the model provider processes it to produce AI analysis results (e.g. titles, labels, extracted fields, the search vectors of the on-device index, search and chat answers) and, apart from the abuse monitoring described below, does not retain it beyond the request either. On the optional route to AI models outside the EU: transient processing on Scandora's server in Germany, in memory only and without storage or logging, to forward the request to Anthropic in the USA and return the answer; Anthropic uses the content only to produce the answer, does not train on it and deletes it within 30 days (flagged requests up to 2 years). On the cloud history sync path: storage of the data listed in section 3 for the purpose of syncing the history across devices. On the server-side DATEV export path (coming soon, see section 1): transient processing of the booking rows and the attached document images to build the DATEV EXTF ZIP, without storage. On the GoBD records path: storage of the capture record and the change-log entry as evidence that a captured file is unaltered and that every later change to its metadata stays traceable. On the import-register path: storage of one register entry per import in Google Firestore (Frankfurt), so that the same source file is not imported twice across the controller's devices. Google may keep prompts sent through managed AI that its automated safety systems flag for up to 90 days, in the Google Cloud region used for managed AI (europe-west3, Frankfurt), only for abuse monitoring; Google does not use them to train models.

3. Type of Personal Data

Document images and the text extracted from them, plus prompts and questions about a document, search queries and, for chat, the on-device-selected passages, and, when a document is indexed for search, its extracted text and AI description, split into passages each headed by the document's title, type and date — sent by the device directly to the model provider, not to Scandora (managed AI, EU route); on the optional route to AI models outside the EU, the page images or text of the chosen document, the question and the model's answer — sent through Scandora's server in Germany (memory only, not stored) to Anthropic in the USA; the history record stored on Scandora's own server, carrying the full text extracted from the document (OCR text, stored up to a 400,000-character cap), a small base64 preview thumbnail of the first page and the record's metadata (title, creation date, page count, file size, labels, chosen export destinations and the fields extracted by the AI such as amount, invoice number and invoice date); the DATEV export payload (transient; the export is coming soon and not yet switched on): the booking rows (per booking the date, gross amount, debit/credit marker, account and contra account, DATEV BU key, invoice number, booking text, recognition confidence and document file name), the export header (Berater number, Mandant number, chart of accounts, fiscal-year start, exported date range, the name set as the exporting user) and the document images attached to those bookings; and the GoBD capture and change records:

per capture a SHA-256 checksum of the captured file, the capture source (camera, network scanner or file upload), a device description, the user and profile identifier and a server timestamp; per document event the document identifier, the event type (capture, edit, export, delete), the user identifier, the acting profile (not for a deletion that Scandora's server makes itself, see section 1), a server timestamp, for an export the chosen destination and, for an edit, the old and the new value of each metadata field that changed (title, labels, gross amount, invoice number, invoice date) — no page image and no document text; and the import-register entry: the source provider, an identifier of the source account, the provider's file identifier and version marker or — for a file picked on the device — a SHA-256 fingerprint of that file's content, the account and profile identifier, the import status, the status and storage reference of each destination and a short-lived device lease, with no page image and no document text; the storage reference is the destination's file URL or the generated PDF's file path and can therefore contain the document's file name. This data may contain special categories of personal data (Art. 9 GDPR) where the controller submits such documents.

4. Categories of Data Subjects

Persons determined by the controller whose data is contained in the processed documents (e.g. clients, customers, employees).

5. Obligations of the Processor

Processing only on the controller's documented instructions, unless Scandora is required to process otherwise by Union or Member State law to which Scandora is subject; in that case Scandora informs the controller of that legal requirement before processing, unless that law prohibits such information on important grounds of public interest (Art. 28(3)(a) GDPR); immediate information to the controller if, in Scandora's opinion, an instruction infringes the GDPR or other data-protection provisions of the Union or of a Member State (Art. 28(3), final subparagraph GDPR); confidentiality of authorised personnel; implementation of the technical and organisational measures (section 8); assistance with data-subject rights and with the obligations under Art. 32–36 GDPR; deletion or return of data at the controller's choice on termination (Art. 28(3)(g) GDPR); the GoBD capture and change records under section 1 are outside that duty: Scandora keeps them as controller for its own evidence purpose, for the ten-year period stated there — a cap Scandora sets itself, not a storage duty imposed on it — and the change log cannot be deleted entry by entry at all; provision of the information needed to demonstrate compliance, and allowing for and contributing to audits, including inspections, conducted by the controller or an auditor mandated by the controller (Art. 28(3)(h) GDPR).

6. Sub-Processors

The controller authorises the sub-processors listed below for the processing described in section 1. For the processing Scandora performs as processor, Annex 1 to this agreement is the authoritative list. Section 7 of Scandora's Privacy Policy (https://scandora.eu/privacy.html) serves a different purpose: it lists every recipient of personal data, including the providers Scandora uses as controller for its own purposes; where the two describe the

same provider, this agreement governs the processor-side processing. Scandora informs of intended changes and grants a right to object. Scandora imposes on every sub-processor the same data-protection obligations as are set out in this agreement (Art. 28(4) GDPR).

7. International Transfers

Where sub-processors process data outside the EU/EEA (e.g. the USA), this is based on the EU Standard Contractual Clauses and/or certification under the EU-US Data Privacy Framework. The data stored under this agreement stays on Scandora's own servers in Falkenstein, Germany, with one exception: the cross-device import register is stored in Google Cloud Firestore in the europe-west3 (Frankfurt) region. Both locations are in Germany, so neither store is a third-country transfer; for the remaining Google Cloud processing around that store the EU Standard Contractual Clauses and/or Google's DPF certification apply. On the EU route (the default), managed AI is called by the device directly, using a short-lived credential Scandora's server issues; the AI call itself is processed in Germany when the Frankfurt regional service (Vertex AI europe-west3) is used, is not a third-country transfer for that leg, and does not pass through Scandora's own server at all. The optional route to AI models outside the EU, used only where a user of the controller has turned it on, is a third-country transfer: the request goes through Scandora's server in Germany to Anthropic, which processes it in the USA under the EU Standard Contractual Clauses (Modules 2 and 3) in Anthropic's data processing addendum, with the UK and Swiss addenda; Anthropic is not certified under the EU-US Data Privacy Framework.

8. Technical and Organisational Measures (TOMs)

Encryption in transit (TLS) on every connection between the app, Scandora's servers and the sub-processors; per-user encryption of stored integration and AI credentials (AES-256-GCM), while for the remaining data stored under this agreement no encryption at rest is claimed as a measure; role-based access control and logging; pseudonymisation of the user identifier (Firebase UID); on the EU route (the default), managed AI is called by the device directly with a short-lived credential, and Scandora's server never receives or stores the document content on that path; on the optional route to AI models outside the EU, Scandora's server holds the content in memory only for the duration of the request and neither stores nor logs it; separation of stored records per user and per profile, readable only with that user's authenticated token; deleting a history record removes it, and account deletion erases every history record and every import-register entry of the account, while the GoBD capture and change records are retained as described in section 1 and are not covered by that erasure — the account deletion replaces the identifiers in them instead, so no retained entry still stores the deleted account's identifiers; hosting of the OAuth components, the credential-issuing endpoint and all data stored under this agreement on Scandora's own server in Falkenstein, Germany, with two exceptions that both stay in Germany: the AI model call on the EU route goes to Google's europe-west3 region (Frankfurt), and the import register is stored in Google Cloud Firestore in the same region; on the optional route to AI models outside the EU, the AI model call goes through Scandora's server to Anthropic in the USA (section 7); regular updates, recoverability and resilience of systems; a process for regularly testing the effectiveness of the measures.

9. Rights of the Controller / Data Subjects

The controller remains in control of the data. Data subjects have the rights under Art. 15–22 GDPR (access, rectification, erasure, restriction, portability, objection). Scandora assists the controller in fulfilling them. For the GoBD capture and change records under section 1 that assistance is limited by their append-only design: access (Art. 15), restriction of further use (Art. 18), export of the entries (Art. 20) and noting an objection (Art. 21) are possible; rectification (Art. 16) or erasure (Art. 17) of a single entry while the self-set retention period stated in section 1 runs is not; as stated plainly there, today nothing removes them once that period expires either. Deleting the account replaces the identifiers in every one of its entries, but the entries stay personal data.

10. Final Provisions

The German version prevails. German law applies. If individual provisions are invalid, the remainder of the agreement remains in force.

Unterzeichnung / Signatures

Ort, Datum / Place, Date: _____

Verantwortlicher / Controller: _____

(Unterschrift / Signature, Name in Druckbuchstaben / printed name)

Auftragsverarbeiter / Processor (Scandora): _____

(Unterschrift / Signature)